

The evidence, traced

Every claim mapped to an experiment, a check and the recorded run — reproduced byte for byte by `redteam verify`.

T6

T6 · Production AI Engineering

Production AI Engineering · evidence

— RE-RUN THE ATTACKS

Same model, same attacks, three systems.

Every attack manipulated the model (19/19). Only the system around it changed.



A · vulnerable toy

19 / 19system compromised
no gates

B · classifier only

13 / 19system compromised
detector in front of an open path

C · hardened

0 / 19system compromised
deterministic enforcement

Same manipulated model; the system is compromised 19, 13 or 0 of 19 times.

Every number below is substituted from the published run's facts (`redteam_poc/evidence/runs/2026-10-07-recorded/facts.json`) and reproduced byte for byte by `redteam verify` . Nothing is typed by hand.

Configuration	model manipulated	system compromised
A — vulnerable toy	19 / 19	19 / 19
B — classifier + unrestricted path	19 / 19	13 / 19
C — deterministic enforcement	19 / 19	0 / 19

3 control scenarios (legitimate work) completed in every arm. 19 attacks across 8 classes.

Claims traced to evidence

Claim	Status	Rests on
A manipulated model does not compromise a hardened system	SUPPORTED	GA-C01: arm C compromised = 0, manipulated = 19
The vulnerable toy is really vulnerable	SUPPORTED (control)	GA-C02: arm A compromised = 19
A classifier is defense in depth, not the boundary	SUPPORTED	GA-C03: arm B compromised = 13
Least privilege is the backbone	SUPPORTED	ablation: registry alone contains 15/19
Argument binding is the sole line against redirection	SUPPORTED	ablation: removing it re-opens 4 (PI-4, RAG-1, BYPASS-2, MEM-1)
Enforcement does not block legitimate work	SUPPORTED	CTRL-C01: 3 controls contained in arm C
Abuse within granted authority is not contained (measured)	LIMITATION OBSERVED	LIMIT-C01: <code>within_residual</code> C = 1/1 (executes in the hardened arm), yet <code>within_compromised</code> C = 0/1 (not a system compromise)

The ablation (each control in isolation, arm C)

Control	Attacks it alone contains	Attacks it is the sole line for
registry (least privilege + MCP pinning)	15	0 (overlap elsewhere)
policy (authorization)	5	0
egress (data boundary)	5	0

Control	Attacks it alone contains	Attacks it is the sole line for
argument binding	4	4
identity / delegation	2	0

How to reproduce

```

cd securing_tools_mcp && make setup
make scenarios      # the corpus across arms A/B/C
make ablation       # each control's contribution
make proof          # record the run under pae-proof/v1
make verify         # EXACT replay + integrity + checks -> VERIFIED
make test           # the import contract, the invariants, the end-to-end assertions

```

No model, no API key, no network: the agent follows a scripted worst-case plan, the clock is fixed and every enterprise system is a local mock. The MCP spec revision referenced throughout is 2026-07-28.

References

Each source is cited for the one passage it supports; verbatim quotes are in `research/sources.md`.

1. Versioning — Model Context Protocol · source
2. Specification overview, "Security and Trust & Safety" — Model Context Protocol, rev. 2026-07-28 · source
3. Architecture — Model Context Protocol, rev. 2026-07-28 · source
4. Tools — Model Context Protocol, rev. 2026-07-28 · source
5. schema.ts (rev. 2026-07-28), `ToolAnnotations` — modelcontextprotocol/specification (GitHub) · source
6. Security Best Practices — Model Context Protocol docs (2026-07-28) · source
7. Security Best Practices — Model Context Protocol docs (2025-11-25), "Session Hijacking" · source
8. Local Server Security — Model Context Protocol docs (2026-07-28) · source
9. Authorization — Model Context Protocol, rev. 2026-07-28 · source
10. Authorization Security Considerations — Model Context Protocol, rev. 2026-07-28 · source
11. SECURITY.md, "Intended Behaviors and Trust Model" — modelcontextprotocol/modelcontextprotocol (GitHub, main) · source
12. The MCP Registry (About; Authentication) — Model Context Protocol docs · source

13. LLM01:2025 Prompt Injection — OWASP Gen AI Security Project · source
14. OWASP Top 10 for LLM Applications 2026 (LLM01:2026 Prompt Injection; LLM03:2026 Excessive Agency) — OWASP Gen AI Security Project · source
15. OWASP GenAI Security Project Unveils 2026 Top 10 for LLM Applications, New Agent Control Standard ... — OWASP Gen AI Security Project (news, 2026-09-01; press text dated Sept. 2, 2026) · source
16. OWASP Top 10 for Agentic Applications for 2026 — OWASP Gen AI Security Project, Agentic Security Initiative (PDF "Version 2026, December 2025") · source
17. Agentic AI – Threats and Mitigations — OWASP Agentic Security Initiative (PDF "Version 1.1, December 2025"; the resource page is dated Feb 17, 2025) · source
18. Agent Control Standard (ACS) — OWASP Gen AI Security Project (resource page dated September 1, 2026) and GenAI-Security-Project/agent-control-standard (GitHub README, ACS v0.1.0) · source
19. LLM06:2025 Excessive Agency — OWASP Gen AI Security Project · source
20. NIST AI 600-1, AI RMF: Generative Artificial Intelligence Profile — NIST (July 2024) · source
21. NIST AI 100-2 E2025, Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations — NIST (Vassilev, Oprea, Fordyce, Anderson, Davies, Hamin; March 2025) · source
22. Technical Blog: Strengthening AI Agent Hijacking Evaluations — NIST Center for AI Standards and Innovation (CAISI; released January 17, 2025, updated December 19, 2025) · source
23. Insights into AI Agent Security from a Large-Scale Red-Teaming Competition — NIST CAISI Research Blog (March 23, 2026) · source
24. Request for Information Regarding Security Considerations for Artificial Intelligence Agents — NIST CAISI, Federal Register Vol. 91 No. 5, pp. 698–701 (January 8, 2026; FR Doc 2026-00206; comments closed March 9, 2026) · source
25. Accelerating the Adoption of Software and AI Agent Identity and Authorization (Concept Paper, DRAFT) — NIST NCCoE (Booth, Fisher, Galluzzo, Roberts; February 2026; comments through April 2, 2026) · source
26. NIST SP 800-207, Zero Trust Architecture — NIST (Aug 2020) · source
27. Prompt injection is not SQL injection (it may be worse) — UK National Cyber Security Centre (blog, published 8 December 2025) · source
28. Greshake, K., Abdelnabi, S., Mishra, S., Endres, C., Holz, T. & Fritz, M. (2023). "Not what you've signed up for: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection." arXiv:2302.12173 (v1 23 Feb 2023) · source
29. Debenedetti, E., Zhang, J., Balunović, M., Beurer-Kellner, L., Fischer, M. & Tramèr, F. (2024). "AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents." arXiv:2406.13352 (NeurIPS 2024 Datasets & Benchmarks) · source
30. Zhan, Q., Liang, Z., Ying, Z. & Kang, D. (2024). "InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents." arXiv:2403.02691 · source
31. Debenedetti, E., Shumailov, I., Fan, T., Hayes, J., Carlini, N., Fabian, D., Kern, C., Shi, C., Terzis, A. & Tramèr, F. (2025). "Defeating Prompt Injections by Design" (CaMeL). arXiv:2503.18813 · source
32. Beurer-Kellner, L., Buesser, B., Crețu, A.-M., Debenedetti, E., Dobos, D., Fabian, D., Fischer, M., Froelicher, D., Grosse, K., Naeff, D., Ozoani, E., Paverd, A., Tramèr, F. & Volhejn, V. (2025). "Design Patterns for Securing

LLM Agents against Prompt Injections." arXiv:2506.08837 · source

33. Nasr, M., Carlini, N., Sitawarin, C., Schulhoff, S. V., Hayes, J., Ilie, M., Pluto, J., Song, S., Chaudhari, H., Shumailov, I., Thakurta, A., Xiao, K. Y., Terzis, A. & Tramèr, F. (2025). "The Attacker Moves Second: Stronger Adaptive Attacks Bypass Defenses Against LLM Jailbreaks and Prompt Injections." arXiv:2510.09023 (10 Oct 2025) · source
34. Wang, Z. et al. (2025). "MCPTox: A Benchmark for Tool Poisoning Attack on Real-World MCP Servers." arXiv:2508.14925 (19 Aug 2025) · source
35. Hou, X., Zhao, Y., Wang, S. & Wang, H. (2025). "Model Context Protocol (MCP): Landscape, Security Threats, and Future Research Directions." arXiv:2503.23278 (v1 30 Mar 2025; v3 current) · source
36. Hines, K., Lopez, G., Hall, M., Zarfati, F., Zunger, Y. & Kiciman, E. (2024). "Defending Against Indirect Prompt Injection Attacks With Spotlighting." arXiv:2403.14720 (Microsoft; 20 Mar 2024) · source
37. MCP Security Notification: Tool Poisoning Attacks — Invariant Labs (blog, 2025-04-01) · source
38. GitHub MCP Exploited: Accessing private repositories via MCP — Invariant Labs (blog, 2025-05-26) · source
39. The lethal trifecta for AI agents: private data, untrusted content, and external communication — Simon Willison (blog, June 16, 2025) · source
40. Agents Rule of Two: A Practical Approach to AI Agent Security — Meta AI (blog, October 31, 2025) · source
41. Mitigating the risk of prompt injections in browser use — Anthropic (Nov 24, 2025) · source
42. Mitigating prompt injection attacks with a layered defense strategy — Google (blog.google/security; Jun 13, 2025; requested at security.googleblog.com, which redirected) · source
43. T1 · Agent Identity — "Agent Identity: Who Is Acting, and on Whose Authority?" · series article
44. T2 · Authorization & Policy — "Your AI Agent Has an Identity. What Is It Allowed to Do?" · series article
45. T3 · Human-in-the-Loop — "APPROVED, but approved what?" · series article
46. F1 · MCP Tool Sprawl — "Your AI Agent Has 500 MCP Tools. Now What?" · series article
47. AI Control Plane — "AI Control Plane: Your Agents Shouldn't Govern Themselves" · series article